

# Hands-On-Learning: Risk-Control Mapping Matrix for a Cloud Environment

# Learning Objectives

By the end of this activity, learners will be able to:

- Identify key risks in a cloud storage environment using principles from NIST SP 800-30.
  - Prioritize identified risks using an ISO 27005-based likelihood and impact assessment.
  - Map prioritized risks to specific ISO 27001 and NIST CSF controls in a matrix.
-

# Description

This lab simulates the work of a security analyst, a core role in any governance program. Learners will conduct a focused risk assessment on a common business scenario—cloud data storage—and produce a risk-control matrix, which is a foundational document for any ISMS. This activity requires learners to synthesize the risk assessment and control mapping concepts taught in Module 2, including the complementary use of ISO and NIST frameworks.

---

# Structure of the Activity

# Tool used

ChatGPT, Microsoft Excel (or Google Sheets) with  
M365 Copilot/equivalent functions.



# Scenario

*You are a security analyst at "Innovate Inc.," a mid-sized enterprise that has migrated its development environment and document storage to a public cloud provider (example, AWS, Azure). You have been tasked with performing a risk assessment on the new cloud storage environment and mapping the top risks to controls for the upcoming ISO 27001 audit. This scenario requires an implicit understanding of the shared responsibility model for cloud security.*

---

# Objective

To identify and prioritize cloud-specific risks and then build a risk-control matrix that visually aligns these risks with appropriate security controls from both ISO 27001 and the NIST CSF.



# Instructions for learners

## **Risk Identification:**

Use ChatGPT as a brainstorming partner. Prompt it to "Identify the top 5 security risks for a company using public cloud storage for sensitive documents, considering the customer's obligations under the shared responsibility model. Frame them as threat/vulnerability scenarios."



## Risk Prioritization:

In an Excel sheet, create a simple risk register with columns for: Risk Description, Likelihood (High/Medium/Low), Impact (High/Medium/Low), and Overall Risk Level.

Populate it with the 5 risks from ChatGPT and assign a Likelihood and Impact score for each, based on the qualitative scales discussed in the course. Determine the Overall Risk Level (example, High Impact + High Likelihood = Critical).

## Control Mapping:

Using your spreadsheet, create a simple matrix. List your top 3 prioritized risks as rows.

List 5-7 relevant controls from ISO 27001 (example, A.5.23, A.8.24) and NIST CSF (example, PR.AC-1, PR.DS-1) as columns.

Place an 'X' where a control directly mitigates a risk, creating a visual map of your control coverage.

# Organize Information Following This Structure for Peer Review

- 1 Title Page:** Project title, your name, and date.
- 2 Risk Register:** Submit a screenshot of your completed 5-item risk register, including your Likelihood/Impact scores.
- 3 Risk-Control Matrix:** Submit a screenshot of your final risk-control matrix.
- 4 Executive Summary:** Write a one-paragraph summary for your manager explaining the highest-priority risk you identified and justifying why the controls you selected are appropriate to mitigate it.

# Instructions for Documenting and Sharing the Project for Peer Review



## 1. Document the Project

Use word processing software to create your report.

Insert the diagram, map, screenshot, or image directly into your Word document, if available.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.

## 2. Share the Project



Save your report and presentation in PDF format.

Upload your documents to the “Peer Review” area in the course shell.

Provide a brief description of your project in the submission post.





### 3. Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.

This activity gives learners a chance to apply the lesson by creating a cornerstone governance artifact that visually communicates risk and control coverage, demonstrating a practical application of multiple industry frameworks in a modern cloud context.